سجل الثغرات والأخطاء الكامل — سيستم الردود والمبيعات

التاريخ: 19-10-2026 · **الفرع المفحوص:** `feat/ai-only-fast-orders`
الأداة: OpenCodeReview الإصدار 1.13.0 من Alibaba · وضع التفويض (بلا مزوّد ذكاء خارجي — بيانات الزبائن ما بتخرج من جهازك).
النطاق: 97 ملف مبرمجة تم تغييرها على الفرع، بواقع 6673 سطر إضافة، مع 1203 اختبار كلها خضرا.

أولاً — الحصيلة

الحالة	العدد	ملاحظة
✅ مغلقة ومصلّحة ومحمية باختبار	23	كلها على هذا الفرع، والبوابات الخمس خضرا
🗑 شالتها قرارات البنية مع الوحدة المحذوفة	11	مواضعها وحدة الربط بمنظومة الطلبيات — شيلت من الأساس
⚠️ لسا مفتوحة (غير حرجة)	6	موجودة بقسم «معلقة» مع تصليحها المقترح

ثانياً — الخروق الحرجة (عالية الخطورة) — القائمة الكاملة وحالتها

#	الثغرة	موضعها بالكود	الحالة والتصليح
1	توقيع ويب هوك الـ OMS يقبل تزييفاً بثابت مخزن بالكود	`webhooks/oms`	🗑 الوحدة شيلت من الفرع كلياً
2	مفتاح الذكاء المشترك (لكل المنصة) كان بيتسرق لعنوان خارجي تتحكم فيه مساحة العمل	`src/modules/ai/router.ts`	✅ منع نهائي: لا مفتاح منصة على عنوان مساحة، إلا بتفعيل صريح من بيئة الخادم `AI_WORKSPACE_GATEWAY_KEYS`
3	نص رسالة الزبون كان يمرّ كامل لمزوّد ذكاء خارجي	`/src/modules/ai/stages`	✅ بوابة الخصوصية تحجب الأرقام والهويات، والمراحل الحساسة مقيدة بالمزوّد الموثوق (على سيرفراتك)
4	فهرسة التزامن: أسماء وعناوين الزبائن تشفّر كاملة للمزوّد الخارجي	`src/modules/knowledge/embeddings.ts`	✅ التصفية وسّعت وطبقت على الفهرس كله

5	وظيفة معلقة (شبكة بلا مهلة) بتجمّد عامل الوظايف للأبد	`scripts/worker.ts` · `src/modules/jobs/service.ts`	✅ مهلة 120 ثانية لكل وظيفة + فشل معرّف وإعادة من المسار العادي
6	حساب المبالغ بالفواصل العائمة — قرش ضايع بالتقريب	`src/modules/orders/pricing.ts`	✅ حساب بتسع صحيحة (وحدة القروش) والتقريب مرة وحدة أواخر الخط
7	وسيط الزبون الخاص كان يطلع بمكتبة المنتجات وسياق الذكاء	`src/modules/catalog/service.ts` · `products/service.ts`	✅ حارس `excludeCustomerInbound()` بكل استعلام + منع إلحاق صورة زبون بمنتج + اختبار مراقب
8	رسالة زبون فاشلة كانت تسكت الدفعة كلها (ضياع صامت)	`src/modules/channels/inbound-job.ts`	✅ أي فشل يرجع الدفعة فاشلة — إعادة التسليم تكمل التدريج
9	مساعد البيع صندوق الصفحة معطّل (جسم فارغ دائماً)	`src/components/inbox/inbox.tsx`	✅ إرسال الجسم صحح على المسار
10	ترقية صلاحيات: الإدارة (ADMIN) تقدر ترفع أو تعزل مالكاً	`src/modules/members/service.ts` · `rbac/owner-guard.ts`	✅ حارس الرتبة: صف المالك ملك المالك حصرياً — الرتبة تقرأ طازجة من القاعدة بكل نداء، وحذف الطلبات على نفس الحارس مع سجل التدقيق

ثالثاً — المتوسطة الخطورة — كلها مغلقة

المشكلة	التصليح المطبق
سجل الأخطاء يحفظ الرابط الكامل فيه هاتف واسم الزبون	✅ يحفظ مسار الصفحة فقط
بريد غير موجود يرد أسرع من موجود — عدّاد بريدات المنصة	✅ تأخير وهمي ثابت، زمن الرد متطابق بالحالتين
سر تلجرام وتيك توك مخزن نص صريح بالقاعدة	✅ تشفير AES-256-GCM والصفوف القديمة تفضل تشتغل لحد ترحيلها
مقارنة سر وظائف الشغل مقارنة عادية	✅ مقارنة بزمن ثابت
رسالة زبون تصير يتيمة عند انهيار بين إنشاء الحدث والطابور	✅ معاملة ذرية على القنوات الخمسة كاملة

جدول حدود الطلبات ما يتفرغ أبدا (نمو بلا نهاية)	✅ كنس ساعي + تفريغ الذاكرة
حساب بلا مساحة لو انهار إنشاء المساحة بعد إنشاء المستخدم	✅ تراجع تلقائي يلغي الحساب اليتيم
انفجار المكدس مع آلاف المستلمين (Math.min)	✅ تجميع تدريجي بدل دالة على المصفوفة كاملة
خطأ تواريخ يرجع 500 بدل 422 ويسمح بنطاق معكس	✅ رمز واضح + رفض المرتجع + سقف 92 يوم
مسار الأسئلة الجاهزة: نقص معرّف يوقع 500	✅ المسار نُظّف وطُبّع
حارس ترتيب الرسائل يأجل جديدة لرسالة قديمة مهجورة للأبد	✅ حد نضارة 30 دقيقة + الوظيفة الحية أثناء التشغيل بتنتظر دائماً
كشف التكرار يمنع طلب متابعة شرعي	✅ التكرار فقط لنفس المنتج بنفس المحادثة
الذكاء يقبل منتج خارج كتالوج الصفحة (طلب من صفحة ما بتبيعه)	✅ بوابة الكتالوج على كل مسارات: الرد وإدخال الطلبات وتعديلها

رابعاً — الصغيرة — مغلقة

- كلمة مرور افتراضية عامة لقاعدة البيانات (postgres/postgres) عند docker-compose → ✅ إلزام كلمة مرور من البيئة + ربط localhost فقط
- تحقق سر تلجرام بمقارنة عادية → ✅ بزمن ثابت
- السجلات المؤقتة القديمة للمنصة → ✅ كنس وأرشفة وتفريغ دوري

خامساً — شلتها قرارات البنية

الفرع شال وحدة الربط مع منظومة الطلبيات (OMS) وباب الوكلاء وجسر الرد الخارجي كلياً — بقرار معماري مقصود. معها راحت النقاط المتوسطة والصغيرة المرتبطة بوحدتها (حوالي 11 بند) لأن الكود اللي بتعلقها برح بعدها. المرجع السابق محفوظ: `docs/CODE-REVIEW-OCR-2026-10-16.md`.

سادساً — المفتوحة (غير حرج) وتصليحها المقترح

البند	الأهمية	التصليح المقترح
`unsafe-inline` CSP للأكواد بالبرمجيات بانتاج	صغيرة	انتقال لـ nonces عبر middleware (Next.js)
الثقة الكاملة في رأس `x-forwarded-for` كعنوان IP	متوسطة	اعتماد عنوان الاتصال الحقيقي بدل الرأس
لا إبطال جلسة عند إيقاف عضو (لا revocation)	متوسطة	فحص حالة العضو `member.status` طازجة مع كل طلب

حل الشكاوى (`handoffs.resolve`) يمرّ بصلاحية `handoffs.claim`	صغيرة	فصل صلاحية مستقلة `handoffs.resolve`
سقف الجسم بالطلب بقراءة `content-length` وحدها	صغيرة	كشف حجم الطلب الحقيقي بعد الوصول، لا بعد الهيدر
تعديل الطلبية من المحادثة يفترض طلب بند واحد	صغيرة (مؤجلة)	لو صار طلب متعدد المنتجات: حساب مخصص لإعادة التسعير

سابعاً — ملاحظات جودة (مش ثغرة)

- استيراد الأكسل ما بيفهم الأرقام بالنسق الأوروبي «1.250,00» — الصف يرجع بسبب واضح، والصيغ العربية والعادية شغالة.
- إشعار تلجرام بطلب جديد بيرسل اسم ورقم عميلك — مقصود: إشعاراتك الخاصة وأنت مالك المنصة.
- الحذف النهائي للمحادثة صار دائماً (كان حذفًا مؤقتًا): قرار معتمد وسجل التدقيق يحفظ الأثر معلومًا.
- توصيف `AGENTS.md` و `docs/INTEGRATIONS.md` لسا بذكر وحدة انشالت — يتثبت بعد دمج الفرع حسب القواعد

ثامنًا — الخصم

- البوابات الشاملة: 1203 · lint · typecheck اختباراً · build · scan secrets — كلها خضرا
- صفر ثغرة حرجة مفتوحة، وكل بند مقفل محمي باختبار ثابت على الفرع
- باقي الشيء القليل: توثيق `AGENTS.md` و`docs/INTEGRATIONS.md` يتحدث بعد دمج الفرع، والحذف المتبقي كله مغطى باختبار.